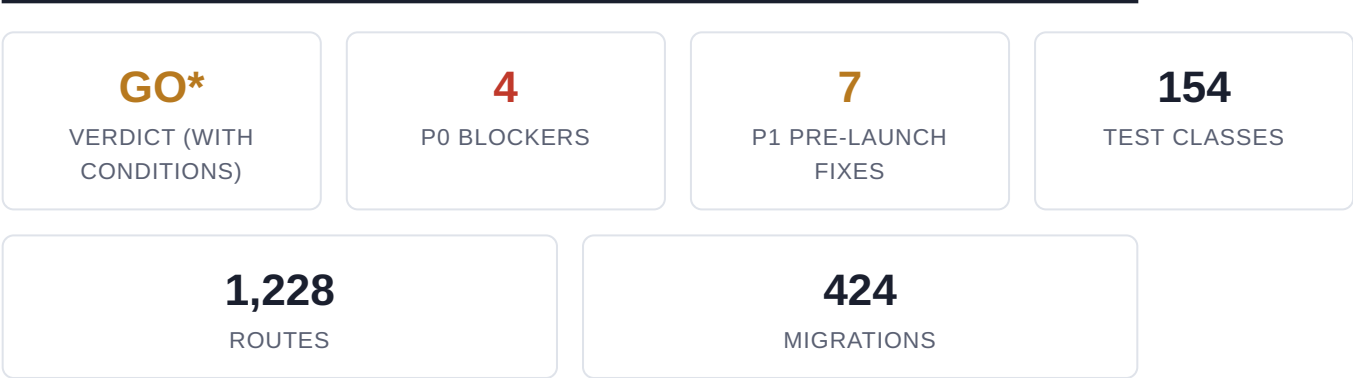


DENTFLUENCE V1 — FINAL PRODUCTION READINESS AUDIT

Scope: Daily production use at **Tulip Dental only** · Date: 7 August 2026 · Basis: full static code audit of **Dentfluence Web** (repo @ b4a1a66, 05 Aug) + governance record · Mindset: *“If it works, freeze it. If it is safe, ship it. If it is not essential, defer it.”*



The one-paragraph truth: The clinical and financial core of Dentfluence is production-grade. Plan lifecycle has a verified single writer, money paths are transactional with row locks and racy-numbering eliminated, invoice/receipt/wallet operations are audit-logged with a daily tamper-check, RBAC is enforced web + API, PHI field encryption is live, and 154 test classes cover the canon. What is **not** ready is the safety net around the app: **there are no backups, no error visibility, one AI chat endpoint that bypasses RBAC entirely, and consultation photos sitting on a world-readable public disk.** None of these needs a redesign. All four are fixable in days. Fix them, deploy, go live.

SECTION 1 — PRODUCTION READINESS: Can Tulip Dental start tomorrow?

No — but it can start in ~7 working days. The daily workflow (register → appoint → consult → plan → visit → bill → pay) works and is safe. The four P0 items below are non-negotiable for a system holding medical records; everything else can follow.

P0 — Critical Blockers (medico-legal / data-loss class)

ITEM	FINDING (VERIFIED IN CODE)	MINIMUM FIX — NO REDESIGN
P0-1 No backups exist	No backup package in <code>composer.json</code> . Zero backup entries among the 22 jobs in <code>routes/console.php</code> . <code>backup.sh</code> exists at repo root but is wired to nothing. A single disk failure on the VPS = every patient record gone.	Wire <code>backup.sh</code> as a nightly cron on the VPS (<code>mysqldump + storage/</code>), copy off-server (<code>rclone/scp</code>), and run one restore drill. ~half a day.
P0-2 AI assistant bypasses RBAC	Verified: <code>AssistantService::runTool()</code> executes any tool with zero permission checks — grep for <code>canAccess Gate:: authorize(</code> across <code>app/Services/Assistant/</code> returns nothing. Any logged-in user (front desk, HR) can read any patient's balance, payments, visit history, KPIs via chat. Enabled by default (<code>ASSISTANT_ENABLED=true</code>).	Set <code>ASSISTANT_ENABLED=false</code> for V1. One env line. Proper per-tool <code>canAccess()</code> gating is V1.1 work. Do not ship the bypass.
P0-3 Consultation photos are public	<code>config/filesystems.php</code> : 62-67 : <code>consultation-photos</code> disk = <code>visibility: public</code> , served at <code>/storage/consultations/...</code> with no auth. Clinical PHI reachable by URL. (Contrast: clinical media correctly uses the private disk + <code>SecureMediaController</code> .)	Repoint the disk to private root and serve through the existing <code>secure-media</code> route. Move existing files. ~half a day; reuses existing plumbing.
P0-4 Failures are invisible	No Sentry/Flare/anything in <code>composer.json</code> . <code>LOG_STACK=single</code> → one unbounded unrotated log. <code>MAIL_MAILER</code> defaults to <code>log</code> → every briefing/SLA email silently vanishes. If cron dies, all 22 scheduled jobs stop with no alert (the runbook itself warns this).	<code>LOG_STACK=daily</code> , set a real mailer, wire the already-present <code>slack</code> log channel to a webhook for <code>critical</code> . Env + config only.

P1 — Must Fix Before Go-Live

ITEM	FINDING	FIX
P1-1 Uncommitted work in tree	5 modified + 9 untracked files — the entire Treatment Visit final sprint (controller, form, partials, print view, new test) lives only on the E: drive. One disk hiccup loses it. Stray duplicate <code>_treatment-visit-bootstrap.php</code> (non-blade) also present.	Delete the stray file, commit, run full suite, tag.
P1-2 Production <code>.env</code> hardening	<code>SESSION_SECURE_COOKIE</code> and <code>SESSION_ENCRYPT</code> commented out in the example; <code>APP_DEBUG=true</code> default; <code>PRM_WA_APP_SECRET</code> unset while the WhatsApp webhook defaults enabled (<code>config/prm.php:104</code>) — its only protection is that secret. <code>.env.example</code> omits every <code>WHATSAPP_/META_/REVIEWS_</code> var.	Set all on prod; rebuild <code>.env.example</code> from the runbook so the next deploy can't miss one.
P1-3 PHI encryption backfill unverified	Encrypted casts are live on Patient/ Consultation/Identifiers, but casts read plaintext gracefully until <code>php artisan patients:encrypt-phi</code> has run. Never confirmed on prod.	Run it on prod; spot-check ciphertext in DB.
P1-4 Lab & vendor attachments on public disk	<code>LabController.php:555</code> / <code>LabCaseAttachment.php:51</code> and <code>VendorInvoiceService.php:73</code> store on the <code>public</code> disk. Lab attachments can carry patient identifiers.	Same private-disk + secure-media treatment as P0-3.
P1-5 Communication queue: no pagination	<code>CommunicationController.php:79-81</code> loads the entire <code>communication_queue</code> with <code>->get()</code> ; the 1,810-item recall backlog already lives there and the engine writes daily. This screen will crawl, then die.	Add <code>paginate()</code> + default status filter. Hours, not days.
P1-6 Recall backlog throttle	1,810 backlogged recall items. WhatsApp is saved today only by <code>WHATSAPP_DRY_RUN=true</code> default. Enabling live sends without a daily cap = 1,810-message blast + Meta ban risk.	Hard daily send cap before flipping dry-run off. (Already a known TODO.)
P1-7 Unthrottled auth-adjacent endpoints	Forgot-PIN and mobile-OTP routes (<code>web.php:45-51</code>) have no <code>throttle</code> ; <code>/hr/scan</code> and <code>/r/{token}</code> are public and unthrottled.	Add <code>throttle:5,1</code> / <code>throttle:30,1</code> . Minutes.

P2 — Can Wait (do after go-live)

ITEM	WHY IT CAN WAIT
P2-1 <code>last_visit_date</code> fires on Consultations only	Writer exists (Observer, monotonic — verified) but treatment-visit-only patients don't advance it, so recall mis-targets them. Recall is throttled/dry-run at launch anyway; wire <code>treatment_visits</code> in V1.1.
P2-2 <code>route:cache</code> skipped in deploy	Closure routes block it; per-request cost on 1,228 routes is tolerable for one clinic. Convert closures later.
P2-3 Payment 20-second dedupe heuristic	Row-lock + 20s identical-payment guard is adequate for one front desk. Client idempotency keys = V1.1.
P2-4 Cascade-delete chains under soft deletes	188 cascade FKs (patient → visits → invoices → receipts) are only dangerous via <code>forceDelete()</code> /raw SQL. Policy rule for now: never hard-delete; no code change needed.
P2-5 Cache store = database, minimal caching	9 <code>Cache::remember</code> calls total. Fine at Tulip's scale. Redis is already configured in env, unswitched.
P2-6 Duplicate migration filename stems, no CI, stale docs	Hygiene. Zero production impact for a single instance where migrations already ran in order.
P2-7 HR sidebar entry ungated	Nav visibility only (<code>sidebar.blade.php:205</code>); routes remain permission-gated. Cosmetic authz tidy-up.

SECTION 2 — MODULE FREEZE REVIEW

MODULE	VERDICT	BASIS
Patients	❏FREEZE	V1.1 hardened + variants, 117 tests green, merge/undo shipped, duplicate-phone warning live, register() sole mint point.
Appointments	❏FREEZE	Overlap conflict now SQL-side (Carbon-500 fix verified in code, in deployed commit range); date-bounded eager-loaded calendar; 13 test files.
Consultations	❏FREEZE	S1–S11 complete and committed (39b1121 “production ready for V1 freeze”), 44 tests, clinical JSON encrypted, wiring observer closes appointments + writes last_visit_date.
Treatment Plans	❏FREEZE	Freeze F1–F5 in; verified only one status writer in codebase (PlanLifecycleService:125); billing-integrity unique index correct with the second-index trap explicitly refused in the migration docblock.
Treatment Visits	⚠ Minor Fixes Only	UX frozen (“approved with minor refinements”), 712/712 reported green — but the whole final sprint is uncommitted (P1-1). Commit → re-run suite → deploy. No feature work.
Billing / Payments / Wallet	❏FREEZE	All money writes in transactions; invoice/receipt numbering row-locked (max+1 race eliminated); wallet locked per-patient; rollback S1 shipped; dedicated financial audit logs.
Inventory	❏FREEZE	Hardened + deployed (9d089f2). Stock ops locked and transactional; GRN reversal + idempotency fields migrated.
Prescriptions	❏FREEZE	Stable, own audit log, syrup-ml dosing + weight shipped.
Lab	⚠ Minor Fixes Only	Works; attachments must move off the public disk (P1-4) and v2 phases need one smoke pass. No rebuild.
PRE / Relationships	⚠ Minor Fixes Only	Engine live; queue screen needs pagination (P1-5); backlog needs throttle (P1-6) before live sends. Largest test suite in repo (20 files).
WhatsApp	⚠ Minor Fixes Only	Code done + CEO-accepted; webhook fail-closed with real HMAC verification; interactive replies wired. Remaining work is external config only (Meta app secret, templates approval). Ship with dry-run until validated.
	❏FREEZE	

Marketing / Blog Hub		Live in production already. (Remember hard-refresh after deploys — no JS cache-busting.)
Reviews	⚠ Minor Fixes Only	Needs <code>REVIEWS_GOOGLE_URL</code> + config to switch on. Launch OFF, enable in week 2. Not a blocker.
Reports / Analytics	❏ FREEZE	Projection-based, rebuilt on 15-min schedule; adequate.
Daily Huddle	❏ FREEZE	Scheduled 08:00, visit-logged wiring shipped.
Membership	❏ FREEZE	Stable; the one mobile module confirmed tested-working.
HR / Attendance	⚠ Minor Fixes Only	Add throttle to public <code>/hr/scan</code> (P1-7); gate the sidebar entry (P2-7).
Settings / Clinic Administration	❏ FREEZE	v2 R1/R2 shipped. Remaining reorganization = V1.1 by definition.
AI Assistant (Tulip)	❏ Production Blocker	RBAC bypass (P0-2). Disable via env for V1; authorization layer → V1.1.
Voice Notes / Receipt Scan	❏ V1.1	Depends on local ollama models; not part of daily core.
ABDM / FHIR · HQ module · DPDP module	❏ V1.1+	Design-only / multi-clinic / deadline 2027. Flags stay off.

SECTION 3 — WEB ↔ ANDROID PARITY

Decision: launch web-first. Android is a companion, not a gate. Parity sits around ~50% and most mobile slices are code-complete but untested. The API layer itself is strong — in fact stricter than web: Sanctum auth, `throttle:120,1`, and per-route `api.role:module:x,action` RBAC across 26 controllers, with the legacy admin string-bypass removed.

Production-critical parity only

- **Usable on Android today (tested):** Membership. Ship. ❏ SHIP NOW
- **Code-complete, untested:** patient profile, treatment plan view, consultation create, prescriptions, record payment, inventory, accounts. Rule for V1: **doctors may read on mobile; all money entry happens on web** until each mobile write-path passes one smoke test. ❏ FIX BEFORE SHIP (the rule, not the code)
- **Everything cosmetic** (Infinity OS reskin, colour cards, quick-add polish): ❏ MOVE TO V1.1

No mobile parity item blocks Tulip's daily operations — the clinic runs on desktop at the front desk and chairside.

SECTION 4 — ACTIVITY LOG / AUDIT TRAIL

This is a strength. Ship it. Generic model auditing (`Auditable` trait → `audit_logs` with user, before/after, IP, device; secrets stripped; audit failure never blocks the write) · auth events logged (login, failed login, logout, 2FA) · dedicated **financial** audit logs (billing, wallet, manual discounts, EMI) · AI tool calls logged to `ai_action_logs` · daily `audit:verify` integrity check that alerts all admins in-app on failure · admin UI for review.

Mandatory gaps (only these)

1. **Re-anchor the audit hash chain after final deploy** — the runbook requires it; skipping makes `audit:verify` scream forever. ☐FIX BEFORE SHIP
2. **Backups are part of medico-legal traceability** — an audit trail that can be lost with the disk isn't one (P0-1). ☐FIX BEFORE SHIP
3. Everything else (log analytics, retention tuning beyond `logs:prune`): ☐MOVE TO V1.1

SECTION 5 — SECURITY REVIEW (production risks only)

AREA	STATUS	EVIDENCE / REQUIRED ACTION
Authentication	OK	Session auth + optional TOTP 2FA enforced pre-login; login throttled 5/min web + API; absolute session timeout 12h enforced by middleware.
Authorization / RBAC	OK	All web routes inside <code>auth</code> group; <code>module:x</code> middleware → <code>canAccess()</code> ; API mirrors per-route. Owner-configured roles are canonical (constitutional rule respected).
AI endpoint	P0	RBAC bypass — disable for V1 (P0-2).
Patient privacy / PHI	P0/P1	Field encryption live (address, complaints, meds, allergies, gov IDs, clinical JSON, 2FA secrets); phone/email deliberately plaintext for search — acceptable. But: consultation photos public (P0-3), lab/vendor attachments public (P1-4), backfill unverified (P1-3).
DPDP readiness	OK for V1	Consent purposes seeded, WhatsApp consent guard ON in prod, service/marketing consent split per template. Full DPDP module deadline is May 2027 — not a launch gate.
Input validation	OK	FormRequest/inline validation throughout; API returns clean error envelopes.
File upload security	P1	Clinical uploads: private disk + authenticated serving + download audit ✓ — but no MIME whitelist (<code>file max:51200</code> only). Add <code>mimes:jpg,jpeg,png,pdf,mp4,...</code> . One-line fix. ☐
Session security	P1	<code>SESSION_SECURE_COOKIE</code> / <code>SESSION_ENCRYPT</code> must be set on prod (P1-2).
Rate limiting	P1	Login/API covered; forgot-PIN, OTP, <code>/hr/scan</code> , <code>/r/{token}</code> unthrottled (P1-7).
CSRF	OK	Zero CSRF exclusions in the whole app; webhook lives on the stateless API stack.
XSS	OK	127 raw echoes audited by sample — all server-controlled icon/SVG markup, not user input.
SQL injection	OK	Eloquent/parameterized throughout; the few <code>whereRaw</code> (overlap check) use bound params.
Secrets	OK	.env + SQL dumps git-ignored (“must never reach GitHub — patient data”); zero hardcoded tokens found by pattern sweep.
Webhooks	OK*	Fail-closed HMAC (<code>hash_equals</code> on <code>X-Hub-Signature-256</code>), rejects when secret unset. *Enabled-by-default → the app secret must be set on prod (P1-2). Unused webhook controllers are unrouted = unreachable ✓.
Backups / DR	P0	None (P0-1). Docker volumes are not a backup.

SECTION 6 — DATA INTEGRITY

AREA	STATUS	EVIDENCE
Transactions	OK	61 files use DB::transaction; every money path verified wrapped (payments, invoices, wallet ×7, plan billing, rollback, discounts, stock ×5, finance).
Concurrency / races	OK	Invoice/Receipt/FinalBill numbering uses <code>lockForUpdate() ->max()</code> inside transactions (max+1 race explicitly eliminated); wallet row-locked per patient; stock locked; stock-count double-submit locked.
Idempotency	OK for V1	Payment double-click blocked by invoice row-lock + 20s identical-submission guard. Heuristic, not key-based — acceptable for one front desk (P2-3).
Duplicate prevention	OK	Patient dup-phone warning (deliberately soft — families share phones); appointment overlap SQL-side with explicit <code>allow_overlap</code> escape hatch; plan-item-teeth protected by DB unique index.
Billing integrity index	OK	Exactly one unique index — <code>(treatment_plan_item_id, tooth_number)</code> . Migration docblock explicitly refuses the forbidden second unique on <code>invoice_item_id</code> and refuses to run over dirty data. Textbook.
Single-writer contracts	OK	Verified: only <code>PlanLifecycleService:125</code> writes plan status in the entire codebase; both controllers mark status <code>prohibited</code> in validation.
FKs + soft deletes	OK*	Soft deletes on every core model (73 migrations); FKs everywhere. *188 cascade clauses = hard-delete landmine → policy: never <code>forceDelete()</code> /raw-delete patients (P2-4).
Migration safety	P2	424 migrations, none newer than 08-04 (the 08-05 sprint is views/controllers only — good). Duplicate filename stems exist but already applied in order on the single instance. Never reorder/move migrations (standing rule).
Rollback safety	OK	Billing rollback S1 shipped; GRN reversal fields migrated; patient merge has undo.

SECTION 7 — PERFORMANCE (bottlenecks only)

- **P1 Communication queue index** — unpaginated full-table `->get()` + 4 clone-count badge queries per load, on a table with a 1,810-row backlog that grows daily. The only screen that will actually fall over. Fix: paginate + default filter (P1-5). ☐ FIX BEFORE SHIP

- **OK** **Dashboard, appointments, patients, timeline** — all verified eager-loaded (`with(...)`), date-bounded or paginated (81 `paginate()` calls across 47 controllers). Patient timeline uses constrained `limit(10)` loads. No action.
- **P2** **route:cache skipped** (closure routes) — measurable but tolerable; convert closures in V1.1. ☐
- **P2** **Cache store = database, ~9 cache calls total** — fine for one clinic; Redis switch is a V1.1 toggle. ☐
- **P2** **Media growth** — local disk via Docker volume; monitor disk in the weekly ops check; S3 is V1.5. ☐

SECTION 8 — QA: minimum testing before launch

Critical (blocks go-live)

1. Commit P1-1, then run the **full PHPUnit suite** against `dentfluencetesting` and confirm the 712-green claim on the committed tree (it has only ever been reported, not independently re-run post-commit).
2. **Money-path smoke**: run `dentfluencetesting:smoke` (rollback mode) on prod after deploy — invoice → payment → receipt → wallet.
3. **Backup restore drill**: take the first backup, restore to a scratch DB, open a patient record. A backup that never restored is a rumor.
4. **RBAC walk**: one pass per real Tulip role (owner, doctor, receptionist) — confirm no access where none is granted, and confirm the assistant chat is gone.
5. **Secure media check**: logged-out request to a consultation-photo URL and a clinical-media URL must both fail after P0-3.

High

1. End-to-end clinical chain on real Tulip data: register → appoint → consult → plan → present → accept → visit → bill → pay → print.
2. Appointment overlap: same doctor/time double-book attempt on prod build (verifies the Carbon-500 fix live).
3. WhatsApp E2E in **dry-run**: reminder render, webhook signature reject (bad HMAC), interactive Confirm/Cancel round-trip.
4. Patient merge + undo on staging data.

Medium

1. Print views (plan, prescription, visit, receipt) on the clinic printer.
2. Android read-path smoke on the tested module set.
3. `docker compose ps` + queue/scheduler health after deploy (the runbook's known crash-loop incident).

SECTION 9 — PRODUCTION GO-LIVE CHECKLIST

ITEM	ACTION / VERIFICATION
Database backup	Nightly mysqldump via <code>backup.sh</code> in cron; off-server copy; restore drill passed; <code>storage/</code> included.
Environment variables	<code>APP_ENV=production</code> , <code>APP_DEBUG=false</code> , <code>SESSION_SECURE_COOKIE=true</code> , <code>SESSION_ENCRYPT=true</code> , <code>ASSISTANT_ENABLED=false</code> , <code>PRM_WA_APP_SECRET</code> , <code>WHATSAPP_*</code> (keep <code>WHATSAPP_DRY_RUN=true</code> initially), <code>MAIL_MAILER</code> real, <code>LOG_STACK=daily</code> , <code>LOG_SLACK_WEBHOOK_URL</code> . Env change ⇒ <code>--force-recreate</code> .
Cron	Scheduler container running; <code>crontab -l grep schedule:run</code> per runbook; all 22 jobs listed in <code>docs/automation-map.md</code> .
Queue workers	<code>docker compose ps</code> shows <code>queue</code> up; after every deploy run <code>queue:restart</code> then restart the container (known stale-timestamp crash-loop).
Storage links	<code>storage:link --force</code> (deploy.sh does it); confirm secure-media routes serve, public <code>/storage/consultations</code> does NOT (post-fix).
SSL	HTTPS on <code>srv1791841.hstgr.cloud</code> ; keep <code>dentfluence.in</code> unexposed (standing directive).
Monitoring / error tracking	Slack log channel on <code>critical</code> ; <code>/up</code> + <code>/api/v1/ping</code> in an uptime pinger; <code>audit:verify</code> daily (already alerts admins in-app).
Logging	<code>LOG_STACK=daily</code> (14-day rotation); <code>logs:prune</code> weekly already scheduled.
Mail	Real mailer configured; send one test briefing.
WhatsApp	Meta app secret set → webhook HMAC live; templates approved in Meta; dry-run E2E passed; daily send cap in place; then flip <code>WHATSAPP_DRY_RUN=false</code> for appointment reminders only.
SMS	None exists — confirm Tulip accepts WhatsApp+email only for V1 (recommended: yes).
Notifications	In-app <code>AppNotification</code> path verified via the <code>audit:verify</code> admin alert.
PHI	<code>patients:encrypt-phi</code> executed; ciphertext spot-checked.
Audit chain	Re-anchored after final deploy per <code>docs/deploy-runbook-2026-07-14.md</code> .
Deploy	<code>bash deploy.sh</code> (migrate <code>--force</code> , <code>config:cache</code> , <code>view:cache</code> , <code>projection rebuild</code> , <code>queue+scheduler restart</code>). Hard-refresh browsers after (no JS cache-busting).
Rollback plan	Runbook ROLLBACK section rehearsed once; DB backup taken immediately before go-live migration.

SECTION 10 — GO / NO GO

⚖️ GO WITH CONDITIONS

Why not NO-GO: the core is genuinely strong — verified single-writer plan lifecycle, transactional locked money paths, enforced RBAC on web and API, live PHI encryption, fail-closed webhooks, zero CSRF exclusions, no hardcoded secrets, a tamper-checked audit trail, and 154 test classes. Nothing in the daily clinical/financial workflow requires redesign or rebuild.

Why not unconditional GO: four P0s are unacceptable for a medical-records system on day one — **no backups, an RBAC-bypassing AI endpoint, publicly readable consultation photos, and total blindness to failures.** Every one of them is env-config or half-day plumbing. That is exactly what “GO WITH CONDITIONS” is for.

Conditions (all four P0 + seven P1, per Sections 1 & 9): complete by Day 7 of the plan below, then start supervised daily use at Tulip.

SECTION 11 — 14-DAY EXECUTION PLAN (fix-before-ship only)

DAY	WORK	GATE
1	Delete stray <code>_treatment-visit-bootstrap.php</code> ; commit the Treatment Visit sprint (P1-1); run full PHPUnit suite; tag.	Suite green
2	P0-3 + P1-4: consultation-photos, lab, vendor attachments → private disk, served via existing secure-media; migrate existing files; add MIME whitelist to clinical upload validation.	Logged-out URL test fails
3	P0-2: <code>ASSISTANT_ENABLED=false</code> + hide nav entry. P1-7: throttle forgot-PIN/OTP/hr-scan/review-token routes.	Chat gone; 429s confirmed
4	P0-1: wire <code>backup.sh</code> nightly (DB + storage), off-server copy, retention 14/60.	First backup exists off-VPS
5	P0-4: <code>LOG_STACK=daily</code> , Slack channel on critical, real <code>MAIL_MAILER</code> , uptime ping on <code>/up</code> . Test one forced error + one mail.	Alert received
6	P1-2: full production <code>.env</code> pass (debug, cookies, session encrypt, PRM secret, WhatsApp keys w/ dry-run); rebuild <code>.env.example</code> . P1-3: run <code>patients:encrypt-phi</code> on prod, verify ciphertext.	Env checklist signed
7	Deploy (<code>bash deploy.sh</code>); re-anchor audit chain; <code>docker compose ps</code> ; run <code>dentfluence:smoke</code> ; RBAC walk per role.	All P0 closed
8	P1-5: paginate communication queue + default filter. P1-6: daily recall send cap. Deploy.	Queue screen <1s
9	Backup restore drill to scratch DB. WhatsApp dry-run E2E incl. bad-HMAC reject + interactive replies.	Restore verified
10	Full clinical-chain UAT with Tulip staff on real data (register → ... → pay → print). Log papercuts, fix only breakages.	Staff sign-off
11	Go-live Day 1 (supervised) : morning huddle, live appointments, billing at the desk. Watch logs all day.	Day survives
12	Triage Day-1 issues; fix only breakages. Enable WhatsApp live for appointment reminders, small capped batch.	Reminders delivered
13	Second supervised day; print-path checks; Android read-only smoke for doctors.	Stable
14	Review week: logs, audit:verify record, backup logs. Declare V1 FROZEN . Open the V1.1 list (Section 13) — nothing enters V1 after today.	Freeze declared

SECTION 12 — FEATURES TO FREEZE NOW

FEATURE	WHY FREEZE
Canonical treatment lifecycle (Plan=promise, Visit=fact, billing from visits)	The supreme contract, implemented and test-canonized. Any change now reopens every module. ☐ SHIP NOW
PlanLifecycleService single-writer	Verified sole writer; the discipline is worth more than any feature. ☐ SHIP NOW
Billing engine (invoices, payments, wallet, EMI, discounts, rollback)	Transactional, locked, audited. Touching money code without a Tulip-reported defect is pure risk. ☐ SHIP NOW
Patients incl. merge/undo, variants, dup-warning	Two hardening rounds + 117 tests. Done means done. ☐ SHIP NOW
Consultations S1–S11	Committed as “production ready for V1 freeze”. ☐ SHIP NOW
Treatment Visit UX (4-zone form, worksheet, print)	UX formally frozen after 9-scenario stress test; standing rule already refuses changes without a Tulip-validated issue. ☐ SHIP NOW (after commit)
Appointments incl. overlap engine	Works; escape hatch exists for deliberate double-booking. ☐ SHIP NOW
Inventory + GRN/reversal	Hardened, deployed, closed. ☐ SHIP NOW
WhatsApp code path (templates, webhook, interactive replies, consent guard)	Code accepted by CEO; only external Meta config remains. Further dev explicitly stopped. ☐ SHIP NOW
RBAC model (owner-configured roles, module permissions, API mirror)	Constitutional; never hardcode job titles. ☐ SHIP NOW
Audit trail + audit:verify	Strong as-is; only the re-anchor step remains. ☐ SHIP NOW
Settings v2 (R1/R2 scope)	Shipped scope frozen; remaining reorg is V1.1 by prior decision. ☐ SHIP NOW

SECTION 13 — MOVE TO V1.1 (everything not required for Tulip production)

ITEM	NOTE
AI Assistant (Tulip) re-enable	Only after per-tool <code>canAccess()</code> gating. ☐
Voice notes · receipt scan (ollama)	☐
Android write-path completion + Infinity OS reskin + all mobile polish	Read-only companion for V1. ☐
UI redesigns of any kind (incl. remaining Settings reorg, dashboard polish)	Standing directive #004 already halts these. ☐
<code>last_visit_date</code> writer for treatment visits (+ <code>consultation_id</code> wiring)	Improves recall accuracy; recall is capped at launch anyway. ☐
Client idempotency keys for payments	20s heuristic suffices for one desk. ☐
Closure-route conversion → enable <code>route:cache</code> ; Redis cache switch; broader caching	☐
CI pipeline, migration-hygiene cleanup, <code>.env.example</code> overhaul beyond the launch rebuild	☐
Reviews module activation, marketing integrations (GBP/ Meta), PPX, microsite	Parked by prior decisions; week-2+ at earliest. ☐
Advanced analytics, insight flags (Phase 6), workflow engine expansion	Built, flags off — keep off. ☐
<code>clinic_id</code> tenant isolation, HQ, multi-clinic, cloud pivot, ABDM, DPDP module, standalone CRM, ecosystem	V1.5/V2/2027 — nothing here affects Tulip tomorrow. ☐
SMS channel	Doesn't exist; WhatsApp+mail cover V1. ☐
S3/off-box media storage	Monitor disk for now. ☐

FINAL CEO DIRECTIVE — SUMMARY OF LABELS

RECOMMENDATION	LABEL
Entire clinical + financial core, RBAC, audit trail, WhatsApp code path, all ❑FREEZE modules (Section 12)	❑SHIP NOW
Backups + restore drill (P0-1)	❑FIX BEFORE SHIP
Disable AI assistant via env (P0-2)	❑FIX BEFORE SHIP
Consultation photos + lab/vendor attachments → private (P0-3, P1-4)	❑FIX BEFORE SHIP
Error visibility: daily logs, Slack alerts, real mailer (P0-4)	❑FIX BEFORE SHIP
Commit uncommitted sprint + re-run suite (P1-1)	❑FIX BEFORE SHIP
Production .env hardening + PHI backfill + webhook secret (P1-2, P1-3)	❑FIX BEFORE SHIP
Communication-queue pagination + recall cap (P1-5, P1-6)	❑FIX BEFORE SHIP
Throttle stray public endpoints + MIME whitelist (P1-7, upload validation)	❑FIX BEFORE SHIP
Everything in Section 13 — without exception	❑MOVE TO V1.1

Prepared 2026-08-07 · Audit basis: three independent full-repo verification passes (security, data integrity, operations) with file-level evidence, spot-checked; governance record 2026-05 → 2026-08.
Verdict: **GO WITH CONDITIONS — 4 P0 + 7 P1, closable in 7 working days, go-live Day 11, V1 freeze Day 14.**